**UNIVERSIDAD COOPERATIVA DE COLOMBIA**

Ideación, Emprendimiento y Desarrollo Tecnológico – Ingeniería de Software

# Anexo D – Diseño preliminar del prototipo VIPY

| | |
|---|---|
| **Proyecto** | VIPY: control de acceso para establecimientos y eventos de aforo controlado mediante credenciales digitales verificables por NFC y QR en dispositivos Android |
| **Integrantes** | Ronald García Muñoz; Luis Miguel Muñoz Rendón |
| **Asesor** | Rodolfo Ortega |
| **Documento de soporte de** | Formato E5 – Objetivos y metodología (OE2, OE3 y OE4; fase F2) |
| **Fecha y versión** | 2 de octubre de 2026 – versión 1 |

## 1. Propósito y alcance

Este anexo presenta el diseño preliminar del prototipo VIPY con el detalle necesario para juzgar su factibilidad técnica antes de la ejecución. Representa los componentes y sus límites de confianza, las interfaces, las secuencias de verificación por NFC y por QR, el ciclo de vida de la credencial, el modelo de datos, la operación sin conexión y las decisiones que siguen abiertas. Responde al hallazgo E5-H17 de la revisión del Momento 2.

El diseño es preliminar: en la fase F2 (S3–S5) se refina y se valida con el asesor, y los valores marcados como tentativos se confirman con las mediciones de F3 y F4. La alternativa diseñada es la seleccionada en la E5: credencial híbrida NFC + QR bidireccional para teléfonos Android, con C4 entendida como cobertura declarada y medida.

## 2. Arquitectura de componentes

El sistema tiene tres partes: la nube del emisor, que crea, firma y revoca las credenciales; el teléfono del usuario, que guarda la credencial y una clave privada que no puede copiarse; y el teléfono del personal de puerta, que verifica sin necesidad de internet. Los recuadros punteados de la Figura 1 marcan los límites de confianza descritos en la sección 3.

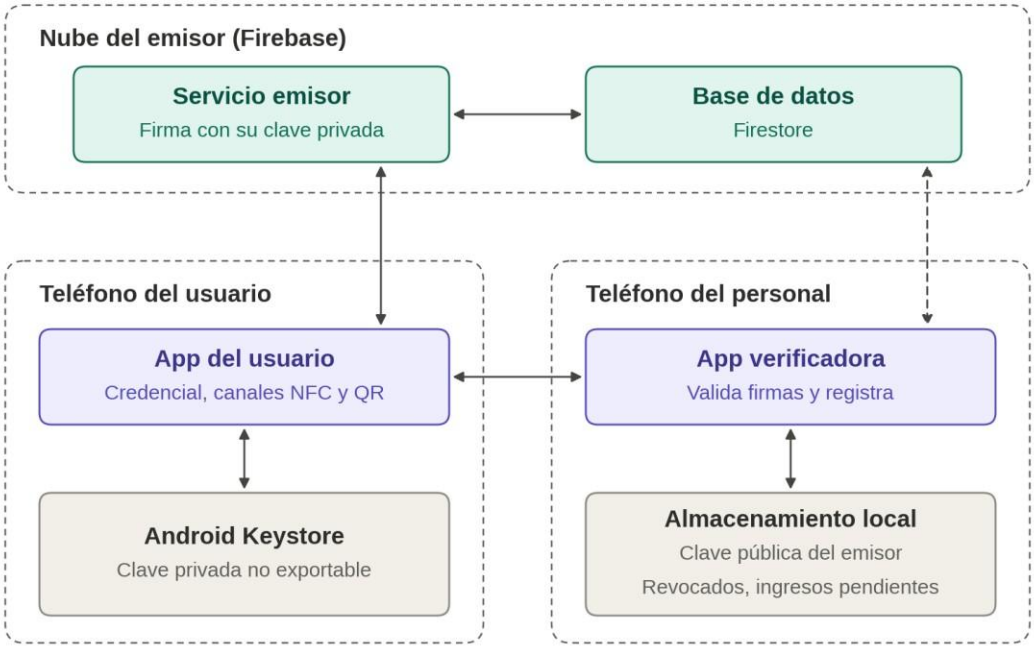



*Figura 1. Arquitectura preliminar de componentes y límites de confianza.*

| Componente | Responsabilidad | Tecnología prevista | Objetivo | Riesgo o recurso (E5–E6) |
|---|---|---|---|---|
| App del usuario | Solicita, guarda y presenta la credencial por NFC o QR; pide la confirmación del usuario antes de firmar. | Android; emulación de tarjeta con HostApduService [7]; cámara y generación de QR. | OE2, OE3 | Comportamiento de HCE (E5, sección 8); teléfonos Android con NFC (E6). |
| Android Keystore | Genera y guarda la clave privada del dispositivo, no exportable; firma los desafíos; entrega la atestación. | Android Keystore con TEE o StrongBox y atestación de claves [42]. | OE2–OE4 | Dependencia de dispositivos con TEE o StrongBox (E5, sección 8). |
| App verificadora | Envía el desafío; valida sello, vigencia, firma y revocación sin conexión; muestra el resultado y registra el ingreso. | Android; modo lector NFC (IsoDep); lector de QR. | OE2–OE4 | Tiempo de espera del lector (E5, sección 8); teléfono del personal. |
| Almacenamiento local del verificador | Guarda la clave pública del emisor, la lista de revocados y los ingresos pendientes de subir. | Base de datos local de la aplicación. | OE3 | Conectividad intermitente en la puerta (E5, sección 8). |
| Servicio emisor | Verifica la atestación; emite y firma credenciales con la clave privada del emisor; las revoca. | Firebase; forma de ejecución por decidir (decisión D1). | OE2, OE3 | Costo del plan (D1); backend de nivel sin costo (E6). |

| | | | | |
|---|---|---|---|---|
| Base de datos | Guarda titulares, credenciales, revocaciones, establecimientos, verificadores y registros. | Firestore. | OE3, OE4 | Cuota gratuita del plan (E6). |

## 3. Límites de confianza

| Zona | Nivel de confianza | Amenaza principal | Control previsto |
|---|---|---|---|
| Nube del emisor | Confiable: guarda la clave privada del emisor y decide emisión y revocación. | Acceso no autorizado a la consola o a la clave del emisor. | Reglas de seguridad de Firestore; cuentas con acceso restringido; la clave del emisor no sale del servicio emisor. |
| Teléfono del usuario | No confiable: puede estar modificado, prestarse o ser atacado. | Copia, captura, préstamo, clonación y repetición. | Clave no exportable en Keystore; atestación al emitir [42]; firma de un desafío nuevo en cada ingreso; confirmación del usuario. |
| Teléfono del personal | Parcialmente confiable: lo controla el establecimiento, pero puede perderse. | Robo del teléfono; lista de revocados desactualizada. | Solo guarda la clave pública del emisor, que no permite emitir; estado activo o retirado del verificador; intervalo máximo de sincronización (D3). |
| Canal NFC o QR | No confiable: puede observarse o retransmitirse. | Repetición, captura y retransmisión. | Desafío único con identidad del verificador y vigencia corta. La retransmisión queda como riesgo residual declarado (E4). |

## 4. Interfaces

| Interfaz | Entre | Protocolo o formato | Datos | Conectividad |
|---|---|---|---|---|
| I1. Emisión | App del usuario y servicio emisor | HTTPS | Solicitud con la clave pública del dispositivo y la atestación; respuesta con la credencial firmada. | Requiere conexión, una vez por credencial. |
| I2. Presentación NFC | App verificadora y app del usuario | ISO-DEP con comandos APDU ISO/IEC 7816-4 [45]; selección por AID [7]. | SELECT AID; desafío (nonce + identidad del verificador); credencial + firma. | Sin conexión. |
| I3. Presentación QR | App verificadora y app del usuario | Códigos QR mostrados en pantalla y leídos con la cámara. | QR de desafío (nonce + identidad del verificador, vigencia corta); QR de respuesta (credencial + firma). | Sin conexión. |
| I4. Sincronización | App verificadora y Firestore | SDK de Firebase sobre HTTPS. | Descarga de revocados y del estado del verificador; subida de registros de ingreso. | Solo con conexión; intervalo por definir (D3). |
| I5. Firma local | App del usuario y Keystore | API de Android Keystore con autenticación del usuario. | Solicitud de firma después del desbloqueo o la huella; firma del desafío. | Local. |

## 5. Secuencia de verificación por NFC

El teléfono del personal selecciona la aplicación VIPY por su AID y envía un desafío que cambia en cada ingreso e incluye la identidad del verificador. El usuario confirma y su teléfono firma el desafío con la clave del Keystore; luego devuelve la credencial y la firma. Los pasos 5 a 7 se ejecutan en el teléfono del personal sin conexión, con la clave pública del emisor y la copia local de la lista de revocados. El resultado y el registro se guardan localmente y se suben a la nube al reconectar.

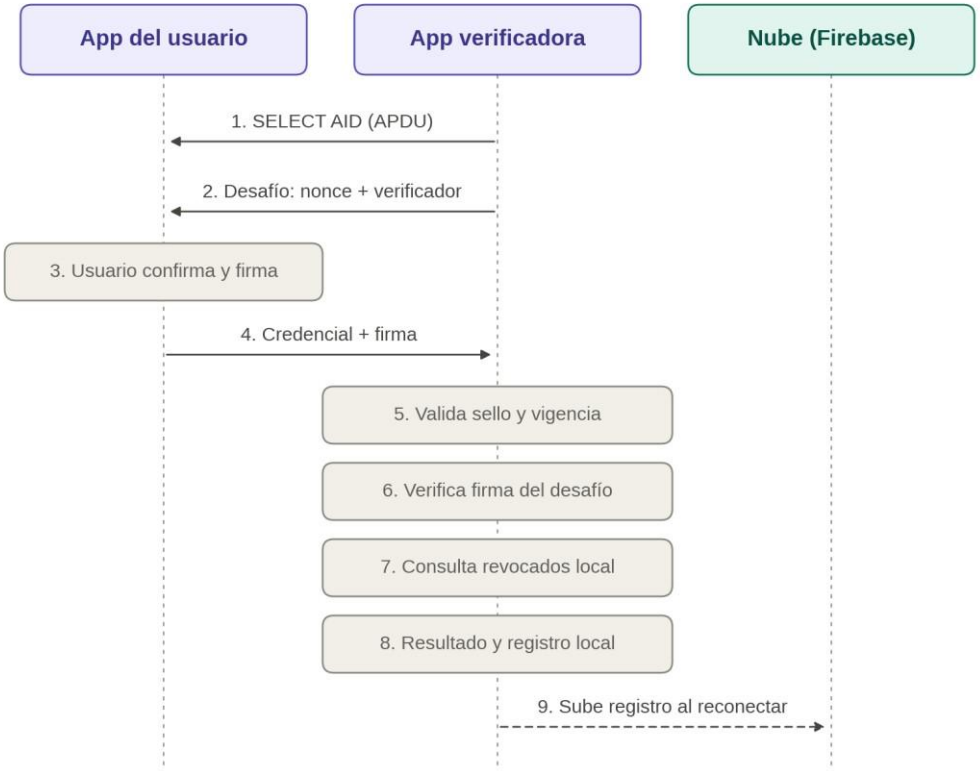



*Figura 2. Secuencia de verificación por NFC.*

Si falla cualquier comprobación, el resultado es "rechazado" y se guarda el motivo (sello inválido, credencial vencida o revocada, firma inválida o desafío caducado). Esos motivos alimentan las pruebas de seguridad de OE4.

## 6. Secuencia de verificación por QR

Es el canal de respaldo para teléfonos Android sin NFC. El teléfono del personal muestra un QR con el desafío y la identidad del verificador, de vigencia corta; el usuario lo escanea, confirma y muestra un QR de respuesta con la credencial y la firma. La validación es la misma del canal NFC, con la comprobación adicional de que el desafío firmado sea el emitido y siga vigente. Así, una captura de pantalla de una respuesta anterior no sirve.

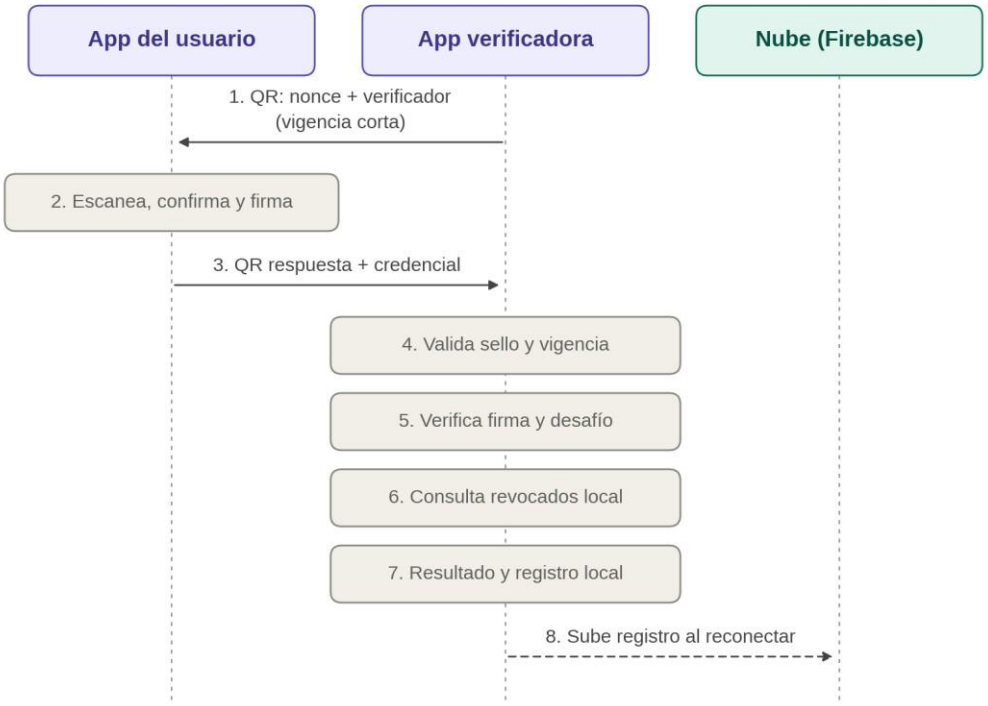



*Figura 3. Secuencia de verificación por QR.*

Riesgo residual: una persona podría fotografiar el QR de desafío, enviarlo a quien tiene la credencial y recibir la respuesta dentro de la vigencia. Es una forma de retransmisión que el diseño reduce con la vigencia corta y la identidad del verificador, pero no elimina; se declara como riesgo residual, en coherencia con la E4, y se prueba en F4.

## 7. Ciclo de vida de la credencial

La credencial solicitada solo se activa si la atestación del teléfono es válida; en caso contrario queda rechazada y nunca se emite. Una credencial activa sirve en cualquier establecimiento que confíe en VIPY (C3). Termina al vencer o al ser revocada por pérdida o robo del teléfono o por retiro del acceso. Como la clave está atada al teléfono, renovar o cambiar de teléfono significa solicitar una credencial nueva. El estado "vencida" no se guarda: el verificador lo calcula con la fecha.

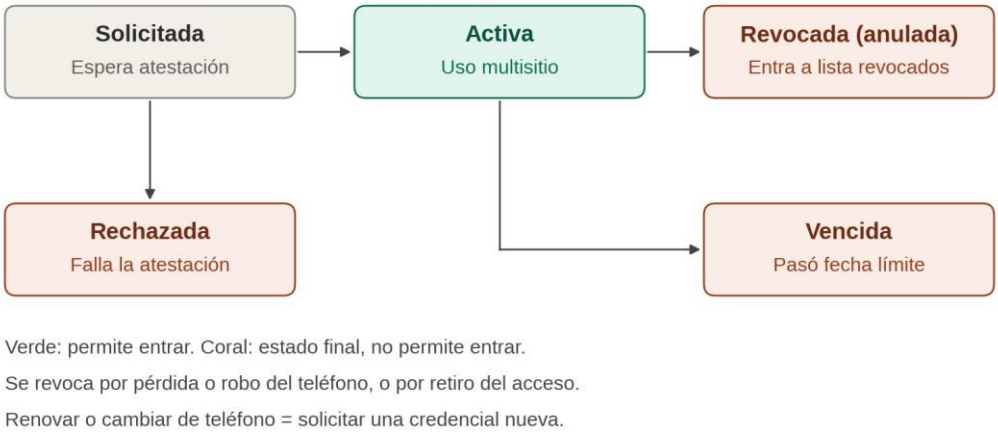



*Figura 4. Ciclo de vida de la credencial.*

## 8. Modelo de datos preliminar

La Figura 5 muestra las entidades principales. La credencial no está ligada a un establecimiento, lo que permite su uso multisitio. El registro de ingreso guarda el motivo de rechazo y admite una credencial vacía cuando lo presentado no es válido.

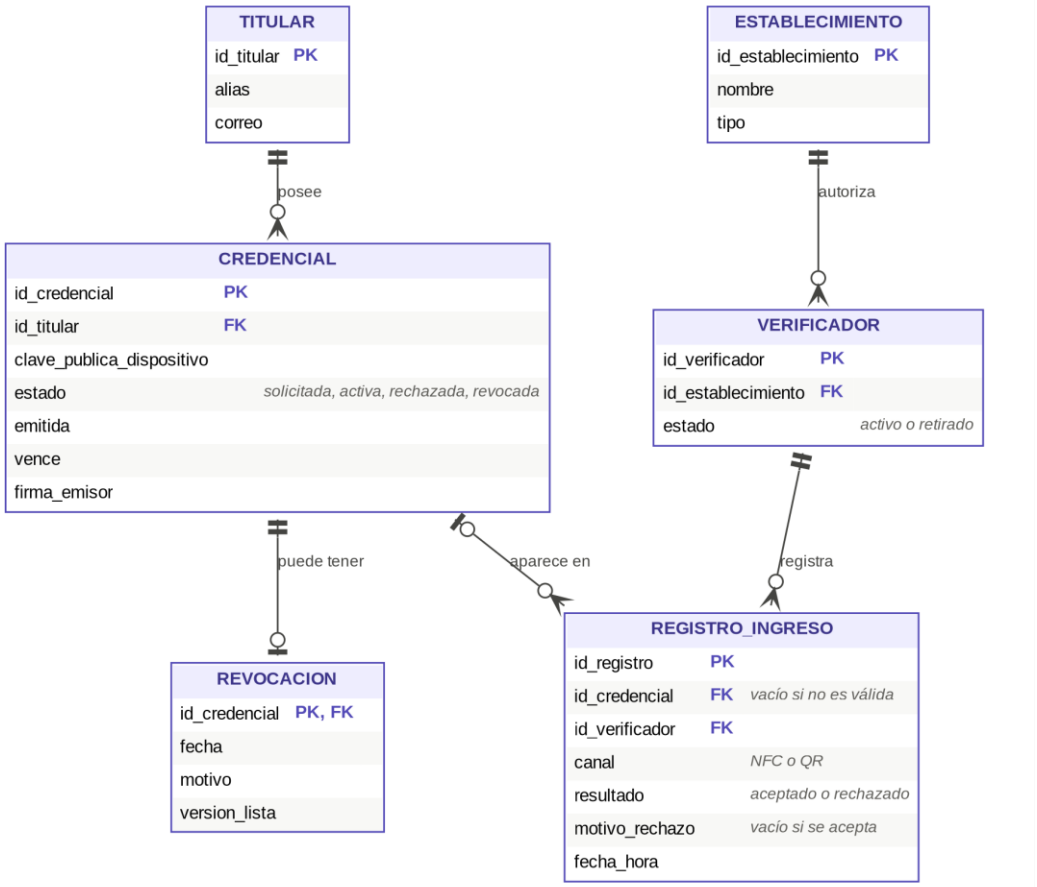



*Figura 5. Modelo de datos preliminar (PK: llave principal; FK: llave foránea).*

| Dato | Nube | Teléfono del usuario | Teléfono del personal |
|---|---|---|---|
| Titular (alias y correo) | Sí (Firestore) | No | No |
| Credencial firmada | Sí (Firestore) | Sí, copia | No; la recibe en cada ingreso |
| Clave privada del dispositivo | No | Sí, en Keystore, no exportable | No |
| Clave privada del emisor | Sí, solo en el servicio emisor | No | No |
| Clave pública del emisor | Sí | Sí | Sí |
| Lista de revocados | Sí (Firestore) | No | Sí, copia sincronizada |
| Registros de ingreso | Sí (Firestore) | No | Sí, mientras no se suben |

Minimización de datos: no se guardan la cédula, la foto ni la fecha de nacimiento. La edad se sigue verificando de forma manual con la cédula en la puerta. El tratamiento de los datos se ajusta a la Ley 1581 de 2012 [53].

## 9. Conectividad y operación sin conexión

La verificación en la puerta no depende de internet: el teléfono del personal valida con la clave pública del emisor y con su copia de la lista de revocados. La conexión solo se necesita para emitir una credencial y para sincronizar. Mientras el verificador no sincroniza, una credencial revocada puede aceptarse; ese intervalo es un riesgo residual que se acota con un intervalo máximo de sincronización (D3) y que ya está declarado en la E5. Los registros se guardan en el teléfono y se suben al recuperar la conexión, sin bloquear la fila.

## 10. Decisiones abiertas

| ID | Decisión | Opciones | Criterio | Se decide en |
|---|---|---|---|---|
| D1 | Dónde se ejecuta el servicio emisor | (a) Cloud Functions, que exige activar el plan con facturación de Firebase aunque el uso quede dentro de la cuota gratuita; (b) un servidor propio de nivel gratuito. | Costo frente al presupuesto de la E6 ($0), protección de la clave del emisor y tiempo de implementación. | F2 (S3–S5) |
| D2 | Vigencia del desafío QR | Valor inicial tentativo de 30 segundos, ajustable. | Tiempo real de lectura frente a la ventana de retransmisión. | F2; se mide en F4 |
| D3 | Intervalo máximo de sincronización de revocados | Al abrir la aplicación y de forma periódica con conexión; valor por definir. | Riesgo residual de aceptar una revocada frente a consumo de datos y batería. | F2; se mide en F4 |
| D4 | Vigencia de la credencial | Por definir. | Frecuencia de renovación frente a exposición en caso de pérdida. | F2 |
| D5 | Identidad del titular | Solo correo; correo más verificación en el establecimiento. | Nivel de autenticación [41] y minimización de datos [53]. | F1–F2 |
| D6 | Algoritmo de firma y formato de la credencial | ECDSA P-256 con formato compacto propio, o formato basado en el modelo de credenciales verificables [43]. | Tamaño del QR, soporte del Keystore y tiempo de verificación. | F2 |
| D7 | Forma de confirmación del usuario | Desbloqueo del teléfono, huella o PIN de la aplicación. | Tiempo en la puerta frente a protección contra retransmisión. | F2; se valida en F5 |
| D8 | Estrategia futura para iPhone | App iOS solo con QR; NFC & SE Platform [54]. | Fuera del alcance del prototipo (E5, sección 5). | Trabajo futuro |

## 11. Trazabilidad con la E5 y la E6

| Elemento del diseño | Objetivo | Fase | Riesgo relacionado (E5) | Recurso (E6) |
|---|---|---|---|---|
| Canal NFC (I2, Figura 2) | OE2–OE4 | F2–F4, iteración 1 | Comportamiento de HCE | Teléfonos Android con NFC |

| | | | | |
|---|---|---|---|---|
| Keystore y atestación (I5) | OE2–OE4 | F2–F4, iteración 1 | Dependencia de dispositivos con TEE o StrongBox | Teléfonos con TEE o StrongBox |
| **Elemento del diseño** | **Objetivo** | **Fase** | **Riesgo relacionado (E5)** | **Recurso (E6)** |
| Servicio emisor y revocación (I1, Figura 4) | OE2, OE3 | F2–F3, iteración 2 | Costo del plan (D1); tiempo de desarrollo | Backend de nivel sin costo |
| Canal QR (I3, Figura 3) | OE2–OE4 | F2–F4, iteración 2 | Retransmisión residual | Teléfono Android sin NFC |
| Operación sin conexión e I4 | OE2–OE4 | F2–F4 | Conectividad intermitente en la puerta | Teléfono del personal |
| Registros con motivo de rechazo (Figura 5) | OE4, OE5 | F3–F5, iteración 3 | Tamaño de la muestra | Participantes del piloto |

## Referencias citadas en el anexo


[7] Android Developers, “Host-based card emulation overview,” Google, s.f. Accedido: 10 sep. 2026. [En línea]. Disponible: https://developer.android.com/guide/topics/connectivity/nfc/hce

[41] D. Temoshok, J. Fenton, Y.-Y. Choong, N. Lefkovitz, A. Regenscheid, R. Galluzzo y J. Richer, “Digital identity guidelines: Authentication and authenticator management,” National Institute of Standards and Technology, Gaithersburg, MD, EE. UU., NIST SP 800-63B-4, jul. 2025, doi: 10.6028/NIST.SP.800-63b-4. [42] Android Developers, “Verify hardware-backed key pairs with key attestation,” Google, s.f. Accedido: 23 sep. 2026. [En línea]. Disponible: https://developer.android.com/privacy-and-security/security-key-attestation

[43] M. Sporny, T. Thibodeau Jr., I. Herman, G. Cohen y M. B. Jones, Eds., “Verifiable credentials data model v2.0,” W3C Recommendation, 15 may. 2025. Accedido: 23 sep. 2026. [En línea]. Disponible: https://www.w3.org/TR/vc-datamodel-2.0/

[45] Identification cards — Integrated circuit cards — Part 4: Organization, security and commands for interchange, ISO/IEC 7816-4:2020, 2020.

[53] Congreso de la República de Colombia, “Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales,” Bogotá, Colombia, 17 oct. 2012. Accedido: 23 sep. 2026. [En línea]. Disponible: https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981 [54] Apple Inc., “NFC & SE Platform for secure contactless transactions,” Apple Developer, s.f. Accedido: 1 oct. 2026. [En línea]. Disponible: https://developer.apple.com/support/nfc-se-platform/ *Las referencias conservan la numeración acumulada del proyecto (E2 a E6).*